

PHISHING EMAIL ANALYSIS

Analyst	Norbert Eigner
Date	2026-06-27
Emails analyzed	2
Classification	TLP:CLEAR — Training / educational use

Note: Both samples below are simulated for a security-awareness project. All links are non-functional, malicious domains are fictional, and IP addresses use the RFC 5737 documentation ranges (192.0.2.0/24, 198.51.100.0/24, 203.0.113.0/24). Reputation counts and file hashes are illustrative placeholders.

Email 1 — Microsoft 365 credential phish (malicious link)

Subject	Unusual sign-in activity on your Microsoft account
From (display / actual)	“Microsoft account team” account-security-noreply@account-microsoft-verify.xyz
Header From (spoofed)	microsoft.com (display only — does not match envelope domain)
Authentication	SPF: FAIL • DKIM: FAIL • DMARC: FAIL (p=reject)
Sender IP & reputation	203.0.113.66 — VPS/hosting ASN; 47 abuse reports on AbuseIPDB (illustrative); no PTR matching Microsoft
From vs Reply-To	MISMATCH — Reply-To = recover-help@mailpunch-relay.top
Link analysis	Button “Verify my account” → <a href="https://account-microsoft-verify[.]xyz/login/?session=8842aa1b&email=<victim>">hxxp://account-microsoft-verify[.]xyz/login/?session=8842aa1b&email=<victim> . urlscan.io (illustrative) renders a pixel-clone of the Microsoft 365 login that POSTs credentials to the attacker host. Victim email is pre-filled via URL parameter.
Other red flags	Generic greeting (“Dear Customer”); 24-hour deadline / account-suspension threat; geo-fear (“Lagos, Nigeria”); X-Mailer reveals PHPMailer bulk tooling.
Verdict	MALICIOUS

Recommended action

- Block sender domain account-microsoft-verify.xyz and reply-to domain mailpunch-relay.top at the secure email gateway.
- Quarantine/purge any copies already delivered; search mailboxes for the subject and sender.
- Submit the URL to Google Safe Browsing and Microsoft (reportphishing@microsoft.com); add domains to the blacklist/SIEM watchlist.
- If anyone clicked: force password reset, revoke active sessions/tokens, and check for new MFA methods or inbox rules.

Email 2 — DHL invoice phish (malicious HTML attachment)

Subject	INVOICE #DHL-2026-44871 OVERDUE - immediate payment required
---------	--

From (display / actual)	"DHL Express Billing" billing@accounts-payable-int.top
Header From (spoofed)	dhl.com (display only — brand impersonation)
Authentication	SPF: SOFTFAIL • DKIM: NONE • DMARC: FAIL
Sender IP & reputation	198.51.100.211 — cheap/abuse-prone VPS host; 12 abuse reports on AbuseIPDB (illustrative)
From vs Reply-To	Match (both = accounts-payable-int.top) — but the domain itself is not a DHL domain (.top TLD, no relation to dhl.com)
Attachment analysis	Invoice_DHL-2026-44871.htm (text/html, base64). Opening it locally renders a fake Office 365 login form that POSTs credentials to an attacker server — an HTML-attachment / browser-in-the-browser style harvester that bypasses URL reputation because no link is in the body. (Sample payload redacted.)
Illustrative file hash	SHA-256: 9f2c4b1e7a... (placeholder)
Other red flags	Highest-priority flag (X-Priority:1); 48-hour threat + "legal recovery action"; unexpected debt/customs fee; ALL-CAPS urgency in subject; payment pressure.
Verdict	MALICIOUS

Recommended action

- Block accounts-payable-int.top; configure the gateway to strip/quarantine .htm and .html attachments (rarely legitimate).
- Alert finance/AP staff specifically — invoice/payment lures target them; verify any real DHL charge through the official portal, never the email.
- Detonate the attachment in a sandbox to extract the credential-POST endpoint; add that host to IOC feeds.
- Report to DHL abuse (phishing-dpdhl@dhl.com) and the hosting provider.

Indicators of Compromise (IOCs)

Sender addresses	account-security-noreply@account-microsoft-verify.xyz recover-help@mailpunch-relay.top billing@accounts-payable-int.top
IP addresses	203.0.113.66 198.51.100.211
Malicious domains	account-microsoft-verify[.]xyz mailpunch-relay[.]top accounts-payable-int[.]top
Malicious URLs	hxxp://account-microsoft-verify[.]xyz/login/? session=8842aa1b&email=<victim>
Malicious attachment	Invoice_DHL-2026-44871.htm — SHA-256 9f2c4b1e7a... (placeholder)

MITRE ATT&CK mapping

Technique ID	Name	Where it applies
T1566	Phishing	Both emails (parent technique)
T1566.002	Phishing: Spearphishing Link	Email 1 — fake Microsoft login link
T1566.001	Phishing: Spearphishing Attachment	Email 2 — malicious .htm attachment
T1598.003	Phishing for Information: Spearphishing Link	Credential harvesting objective of both lures
T1656	Impersonation	Brand spoofing of Microsoft and DHL
T1078	Valid Accounts	Likely follow-on if harvested credentials are used to log in

Summary: Two credential-harvesting phishing emails using brand impersonation and urgency. Both fail email authentication (SPF/DKIM/DMARC), a decisive technical tell. Primary controls: enforce DMARC reject, block listed IOCs, strip risky attachments, and run user awareness on urgency + sender/link mismatch.